Longevity Plate · Báo cáo Lab3

PRM393 · Flutter, Firebase và backend tích hợp
Nghiệm thu trên Android thật · 13–14/11/2026

Longevity Plate hỗ trợ ghi nhật ký bữa ăn, tìm hiểu kiến thức ăn uống và lập kế hoạch tuần. Người dùng đăng nhập Google để tách dữ liệu theo tài khoản. Ứng dụng lưu trên thiết bị trước, sau đó đồng bộ với backend; ảnh và báo cáo được lưu trên Cloudinary. Web riêng phục vụ quản trị viên gửi thông báo và xem dữ liệu vận hành, bao gồm sự cố Crashlytics thật.

Dịch vụ Lab3	Tích hợp trong dự án
Authentication	Google sign-in qua Firebase Auth; Firebase ID token bảo vệ API.
Lưu trữ	Cloudinary JPEG/PDF authenticated, signed upload và owner download.
Cloud Messaging	FCM HTTP v1 từ backend; Android permission, lịch sử và deep link.
Analytics	Đo sự kiện của ba flow; telemetry không làm hỏng luồng chính.
Crashlytics	Handled error/non-fatal và nút native crash; Admin đọc REST API.
Remote Config	Hai tham số có defaults/cache và cập nhật realtime.

Cloudinary thay Firebase Storage theo hướng dẫn bổ sung của giảng viên. Thiết bị nghiệm thu: OPPO CPH2637, Android 16/API 36, ARM64. Frontend mobile dùng Flutter; backend dùng Cloudflare Workers/Hono/TypeScript và D1; Admin dùng React/TypeScript/Vite.

Firebase project: longevity-plate-beff9
Git branch: feature/backend-admin-offline-sync
https://longevity-plate-lab3-staging.longevity-plate-dai05.workers.dev

Repository GitHub · Web Admin staging



Hình minh họa giao diện thương hiệu, lấy từ assets của dự án.

1. Ba flow và cách phân lớp

F01 · Đăng nhập và mục tiêu

Từ màn giới thiệu, người dùng đăng nhập qua hộp chọn Google của Android. Firebase Auth khôi phục phiên, ứng dụng tải dữ liệu theo UID rồi quyết định vào màn mục tiêu hay Home. Không chọn mục tiêu thì xuất hiện validation. Hủy đăng nhập giữ người dùng ở màn đăng nhập. Sau logout, route guard bảo vệ Nhật ký, Kế hoạch và Tài khoản.

F02 · Ghi bữa ăn có ảnh

Người dùng chọn ngày, loại bữa, chụp hoặc chọn ảnh và nhập tên món tối đa120 ký tự. Nội dung bắt buộc được kiểm tra trước khi lưu. Ảnh picker được sao chép vào app sandbox để không lệ thuộc đường dẫn tạm. Một transaction lưu meal và outbox; UI có thể hiển thị ngay dữ liệu local. Bản nháp có xác nhận bỏ thay đổi; lỗi lưu giữ nội dung để thử lại.

F03 · Kiến thức đến kế hoạch

Người dùng đọc bài, mở công thức, chọn ngày/bữa và thêm vào kế hoạch. Slot đã có món thì phải xác nhận thay thế; chọn Hủy giữ món cũ. Tìm kiếm hỗ trợ bỏ dấu; truy vấn không khớp có empty state. Nguồn WHO mở bằng trình duyệt Android và quay lại bằng Back.

Tầng	Trách nhiệm	Vị trí
View	Hiển thị loading/data/empty/error; nhận thao tác.	lib/views/
ViewModel	Validation, điều phối repository, trạng thái UI.	lib/viewmodels/
Repository / service	Dữ liệu local, sync, Firebase và media.	lib/services/

Provider cung cấp phụ thuộc và ViewModel; GoRouter quản lý điều hướng. View không giữ service-account secret hoặc tự quyết định quyền Admin. Tách tầng giúp test validation và xử lý lỗi độc lập với provider thật.

2. Kiến trúc và dữ liệu

Luồng dữ liệu chính: **Flutter → SQLite/outbox → Worker API → D1**. Với media, Worker cấp chữ ký, client upload trực tiếp Cloudinary, rồi Worker xác nhận metadata trước khi gắn asset vào record. Các SDK Auth, Messaging, Analytics, Crashlytics và Remote Config chạy phía app theo vai trò của từng dịch vụ.

Thành phần	Dữ liệu và vai trò
SQLite native	local_records, outbox, sync_meta; cache theo UID và cursor.
D1 records	Profile, goals, meals và plans dạng record có revision, created/updated/deleted timestamps.
D1 changes / idempotency	Cursor thay đổi; kết quả operation theo opId để retry ổn định.
D1 assets	Owner, kind, hash, publicId, size, status, meal revision; file ở Cloudinary.
Devices / deliveries	Token gắn installation/UID/generation; campaign và kết quả từng thiết bị.
Admin / audit / snapshots	Allowlist, hành động quản trị, snapshot Crashlytics có source/fetchedAt.

Ranh giới client và server

Dữ liệu nghiệp vụ và metadata được quản lý ở D1. SQLite giữ dữ liệu local và operation chưa xác nhận. Worker là nơi kiểm tra Firebase JWT, ownership, revision, Admin role, rate limit và payload. Cloudinary API Secret cùng private key chỉ nằm trong biến bí mật của server. Client nhận public config và chữ ký ngắn hạn cho hành động đã được cấp phép.

lib/services/sync/backend_api.dart
lib/services/sync/local_sync_store.dart
lib/services/sync/sync_engine.dart
server/src/worker.ts, records.ts, media.ts, notifications.ts
server/migrations/0001_core.sql → 0003_record_creation.sql

Staging có Worker và database riêng. Không deploy đè production, không thay billing. Các kiểm tra cloud tạo fixture có UUID, kiểm tra owner A/B rồi cleanup đúng fixture đó.

3. Authentication và bảo vệ API

Google OAuth xác nhận tài khoản; Firebase Auth phát hành ID token có chữ ký. App lấy token từ SDK khi gửi request, đặt vào header Authorization. Worker xác minh chữ kýRS256 theo Google public keys, kiểm tra kid/issuer/audience/thời hạn và subject. UID của request lấy từ token đã xác minh, không tin UID trong form hoặc query.

Cơ chế	Áp dụng
401 / refresh	Token sai hoặc hết hạn bị từ chối; client thử forceRefresh đúng một lần.
Owner isolation	Các truy vấn ràng buộc UID; đọc/sửa/confirm/link asset người khác thất bại.
Admin allowlist	Server kiểm tra UID trong admin_users ở mọi route Admin. User thường nhận403.
Validation / SQL	Zod kiểm tra body; SQL chuẩn bị sẵn; giới hạn body/rate và CORS.
Session boundary	Kiểm tra UID trước/sau await; dữ liệu và queue không chuyển sang tài khoản kế tiếp.

ID token khác FCM token

ID token chứng minh người dùng đối với API. **FCM registration token** là địa chỉ của một app instance để gửi push. Biết FCM token không cấp quyền đọc nhật ký hoặc trở thành Admin. Không đặt token hoặc private key vào Analytics, URL công khai, source Git hay slide.

Client: FirebaseAuthService.idToken / BackendApi.call
Server: providers.ts / verifyFirebaseToken và worker.ts / admin guard

Web Google login đã được người dùng xác nhận. API E2E sử dụng Firebase-issued ID token thật và kiểm tra quyền giữa hai tài khoản. Nguồn: Firebase ID token verification.

4. Ảnh bữa ăn và báo cáo PDF

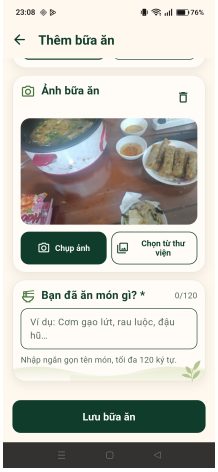
Bước	Hành động	Ràng buộc
1	Camera/gallery → chuẩn hóa JPEG → app sandbox.	Giữ draft theo owner; hủy picker không tạo meal.
2	Meal local → outbox → D1 có version.	Ảnh được gắn với mealId/mealVersion.
3	POST /media/sign với hash và loại asset.	Worker xác minh JWT, owner, limit; secret ở server.
4	Client multipart upload trực tiếp Cloudinary.	Authenticated delivery; không public secret.
5	POST complete hoặc reconcile nếu mất response.	Worker kiểm tra provider metadata và receipt.
6	Xin owner URL rồi hiển thị/tải ảnh hoặc PDF.	Link có hạn15 phút; caller phải sở hữu asset.

Ảnh tối đa5 MiB, PDF tối đa10 MiB theo ứng dụng. Asset dùng hash và ID ổn định, không overwrite tùy ý. Một meal chỉ có một ready photo; revision ngăn upload đến trễ ghi đè thay đổi mới. Khi xóa meal, server tạo tombstone và queue cleanup asset; không xóa file người dùng khác.

Xuất báo cáo

ReportBuilder tạo PDF từ nhật ký của UID hiện tại. ConnectedReportStorage dùng upload có tiến độ, xác nhận asset rồi xin link tải. D1 giữ metadata, Cloudinary giữ tệp. Endpoint PDF cũ được giữ tương thích; metadata file cũ không tự được suy đoán hoặc backfill thiếu kiểm tra owner.

Provider smoke đạt15/15, gồm JPEG/PDF, metadata, private download và unsigned denial. Staging E2E kiểm tra userB không thể xác nhận hoặc xin link asset của userA. Luồng native trên CPH2637 cũng đọc được ảnh riêng tư sau upload.



Preview từ photo picker trên CPH2637. Sau lưu: D1 version 2, private JPEG228.597 byte HTTP 200; xem device-gallery-proof.json.

Code: device_meal_photo_service.dart / connected_storage.dart / backend_api.dart / server/src/media.ts

Nguồn: Cloudinary signed upload; Authenticated assets and private download

5. Offline sync, retry và conflict

SQLite là nguồn dữ liệu cục bộ khi bật API sync. Một transaction ghi record cùng operation vào outbox. UI đọc cache theo UID nên vẫn xem và ghi được dữ liệu trong lúc API không truy cập được. Legacy SharedPreferences được giữ làm backup sau migration theo từng UID.

Khái niệm	Cách xử lý trong dự án
opId ổn định	Retry dùng lại operation cũ; server trả kết quả idempotency thay vì tạo thêm record.
baseVersion	Mutation chỉ áp dụng nếu revision hiện hành phù hợp. Xung đột trả current record.
Frozen operation	Sau lần thử đầu không tự đổi nội dung operation; edit mới có operation mới.
Retry / backoff	Số lần tự thử có giới hạn; người dùng có màn trạng thái và Đồng bộ lại.
Cursor / tombstone	Pull thay đổi tăng dần; xóa được truyền sang client để tránh hồi sinh dữ liệu.
Photo revision	Ảnh local chờ meal đồng bộ; giữ base revision để không đè ảnh mới từ phía khác.

Ví dụ hai client cùng sửa

Cả hai đọc version2. ClientB lưu trước, server thànhversion3. ClientA gửi operation dựa trênversion2 thì nhận conflict. App giữ nội dung local để người dùng quyết định dùng bản trên server hay giữ local trên revision mới. Không âm thầm ghi đè. Đọc sau logout hoặc khi UID đã đổi bị chặn.

Các regression kiểm tra disk outbox, close/open database, retry không trùng, cursor, xóa, ảnh revision và session owner. Nghiệm thu native dùng SQLite Android và dịch vụ cloud thật; nếu dùng HTTP failure có kiểm soát thì ghi rõ điều kiện đó, phân biệt với ngắt Wi-Fi hoặc kill tiến trình Android.

Code: LocalSyncStore.write / next / resolve / applyPull
SyncEngine.synchronize / retryAll / _uploadPhotos
UI: lib/views/sync_screen.dart

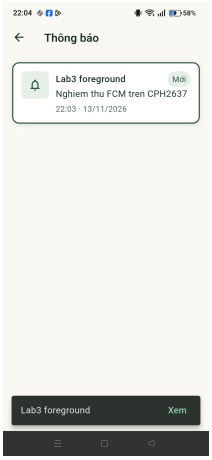
6. FCM từ Admin tới điện thoại

Firebase Messaging SDK lấy registration token từ FCM cho app instance. App đăng ký token vào backend theo UID hiện tại, nghe tokenRefresh và hủy đăng ký khi logout. Installation secret/generation giúp request cũ đến trễ không chiếm lại owner sau đổi tài khoản. Admin chỉ thấy metadata thiết bị; API không trả token đầy đủ.

Admin preview/confirm → POST /admin/push → Worker lấy token active của UID đích → OAuth service account → FCM HTTP v1. Campaign có requestKey ổn định; delivery ghi accepted/error/attempts/openedAt. Token invalid bị vô hiệu hóa; timeout không rõ kết quả không được tự resend vô hạn.

Trạng thái máy thật	Quan sát trên CPH2637	Kết quả
Foreground	SnackBar “Lab3 foreground” và lịch sử S12.	Đạt
Background	Notification Android; chạm mở Nhật ký; openedAt15:05:19Z.	Đạt
Terminated	PID rỗng trước gửi; notification đến; mở đúng Nhật ký; openedAt15:06:05Z.	Đạt
Quyền Android13+	Banner quyền tắt → Bật thông báo → hộp thoại Android → Allow → đăng ký device.	Đạt

Accepted chỉ là FCM nhận request. Kết luận trên được bổ sung bằng UI điện thoại và openedAt, không suy ra giao nhận chỉ từ HTTP 200. onMessage phục vụ foreground; onMessageOpenedApp/getInitialMessage đưa về route đã kiểm tra sau khôi phục phiên.



Thông báo foreground trên CPH2637: SnackBar và lịch sử S12 cùng hiển thị tin thử.

Client: firebase_messaging_service.dart / notifications_view_model.dart
Server send code: server/src/notifications.ts / deliver
Android package: com.longevityplate.longevity_plate

Nguồn: Flutter FCM setup; Send HTTP v1

7. Analytics và Remote Config

Analytics theo dõi hành vi của ba flow bằng event có tên và thời điểm phát rõ. meal_saved được phát sau khi lưu thành công. Event parameters không chứa email, tên món nhập tự do hoặc token. ResilientAnalyticsService tách lỗi đo lường khỏi nghiệp vụ, để telemetry không biến một bữa đã lưu thành lỗi rồi tạo trùng khi retry.

Nhóm	Sự kiện minh họa
Tài khoản / onboarding	login, logout, tutorial_begin, tutorial_complete
Nhật ký	meal_add_start, meal_saved, meal_save_failed, meal_draft_discarded
Kế hoạch / báo cáo / push	plan_slot_saved, report_exported, notification_opened

DebugView dùng để đối chiếu event/parameters trong phiên demo. SDK có thể hoãn tải khi offline. Evidence Analytics cũ được lưu theo ngày; không coi unit tests hoặc log giả là ảnh Console của build hiện tại.

Hai tham số Remote Config

Tên	Default	Tác động
max_knowledge_results	3	Giới hạn số bài trong thư viện.
suggested_recipes_enabled	true	Hiện/ẩn nhóm món gợi ý.

Ứng dụng cài defaults trước, dùng giá trị đã activate/cache, fetchAndActivate khi tải lại và activate khi nhận onConfigUpdated. Đã publish 3/true → 1/false → 3/true (khôi phục ở version5); UI CPH2637 cập nhật trong cùng APK. Mất mạng giữ cache hoặc default. Remote Config không giữ API Secret và không thay thế quyền server.

Code: AnalyticsEvents / FirebaseAnalyticsService / ResilientAnalyticsService
RemoteConfigKeys / FirebaseRemoteConfigService

Nguồn: Analytics DebugView; Flutter Remote Config

8. Crashlytics thật và Web Admin

Handled errors được ghi non-fatal, UI vẫn giữ dữ liệu và cho retry. Nút Gây crash thử nghiệm có xác nhận rồi gọi FirebaseCrashlytics.instance.crash(). Sau khi mở lại, SDK gửi báo cáo. UserID và custom key route gắn ngữ cảnh; logout xóa liên kết người dùng trước.

Bằng chứng crash mới	Giá trị đối chiếu
Android crash log	FirebaseCrashlyticsTestCrash lúc22:11:28 ngày13/11/2026.
Issue mới	ece9690113b884780b157ecd849ebd37
Event time	2026-11-13T15:11:28Z
Device / OS / app	CPH2637 / Android 16 / 1.0.0
Admin API	Refresh và issue/events HTTP 200; tổng5nhóm sau lần crash mới.

Dev xem Firebase Console; Admin dùng Web riêng. Worker gọi Crashlytics REST v1alpha bằng OAuth service account có Viewer role được người dùng cho phép. Snapshot D1 có source/fetchedAt; không tự tạo crash record từ nút bấm. Refresh có cooldown60 giây; dữ liệu có thể đến sau một khoảng xử lý của Firebase.

Web dành cho quản trị viên

React/TypeScript/Vite có overview, users, devices, gửi push và history, PDF metadata, audit, Crashlytics. Google Auth chỉ là bước xác thực; Worker kiểm tra allowlist cho các API Admin. Lỗi auth/internal-error do CSP chặn Google loader đã được sửa bằng danh sách domain cụ thể và browser regression. Người dùng đã vào dashboard thật.

Flutter: account_screen.dart / firebase_crash_service.dart
Backend: providers.ts / worker.ts
Web: admin/src/App.tsx / api.ts / auth.ts; CSP: admin/public/_headers

Nguồn: Crashlytics REST · Web staging

9. Kết quả kiểm thử và CI

Lớp kiểm tra	Kết quả	Phạm vi
Flutter	102/102	Unit/widget, navigation, layout, repository, sync, owner và timeout.
Backend	55/55	10compatibility +45Workers/D1 với RSA test key/provider fixtures.
Admin components	8/8	Auth/role, loading/empty/error, push confirm, crash, logout.
Browser	4/4	Chromium desktop/mobile, CSP regression; API/auth fixtures.
Cloudinary provider	15/15	Dịch vụ thật: JPEG/PDF, receipt, metadata, private/unsigned denial.
Staging API E2E	40/40	Firebase ID token, remote D1, ownerA/B, media và Crashlytics thật.
Android native	2/2	Online media; SQLite reopen, retry và second-client conflict thật.
FCM / crash hardware	Đạt	Ba trạng thái FCM; crash mới khớp device/time trên API Admin.
GitHub Actions	2 job đạt	backend-admin và flutter, run43465913095.

Tổng169 ca automated local được phân biệt với kiểm tra provider và thiết bị thật. Flutter analyze không có issue; line coverage3246/3994=81.27%. Fresh npm ci từ lockfile và npm audit của server/Admin không có advisory tại lần kiểm tra. OpenAPI có34 paths/41 operations/15 schemas và kiểm tra references/security/path parameters.

CI dùng test credentials/fixtures, không cần production secrets, không continue-on-error. Pattern scan kiểm tra source và Git ignore chặn .dev.vars, private backup, token/log/APK. Đây là một lớp kiểm tra bổ sung, không phải cam kết kiểm toán bảo mật toàn diện.

GitHub Actions run43465913095 · Source nhánh tích hợp

10. ARTEMIS và kiểm thử khám phá

ID	Tình huống	R1 / R2 / R3
AR01	F01 / native Google account chooser	PASS / PASS / PASS
AR02	F01 / validation	PASS / PASS / PASS
AR03	F02 / create meal	PASS / FAIL / FAIL
AR04	F02 / required fields	FAIL / FAIL / FAIL
AR05	F02 / discard	PASS / PASS / FAIL
AR06	F03 / knowledge to meal plan	PASS / PASS / PASS
AR07	F03 / cancel replacement	FAIL / FAIL / FAIL
AR08	knowledge search / empty state	PASS / FAIL / FAIL
AR10	native Android browser / system Back	PASS / PASS / PASS
AR13	native Android photo picker / F02	FAIL / FAIL / FAIL

Official ARTEMIS CLI chạy trên CPH2637: 10 ca ×3 lượt, lưu36 attempts gồm retry. Đối chiếu ảnh, UI hierarchy và D1: **16/30 PASS (53,33%), 14/30 FAIL**. Không lấy SUCCESS làm tiêu chí đạt. Thiếu quan sát trong trace được tính FAIL; không suy ra mọi FAIL là lỗi ứng dụng.

AR04 thiếu dấu vết lỗi tên món; AR07 chưa mở đúng công thức khác. AR13 chọn sai fixture và một lượt đi sang ứng dụng khác nên bị dừng. Runner hiện khóa chạy không giám sát; --locked-app không phải sandbox. Nhật ký gốc được giữ nguyên để truy vết.

Phiên khám phá có giám sát trên CPH2637 kéo dài 16.04 phút; kết quả ghi riêng trong EXPLORATORY_SESSION.md. Các kiểm tra thủ công không thay kết quả ARTEMIS hoặc được cộng thành lượt agent.

Chi tiết: docs/ARTEMIS_RESULTS.md; ARTEMIS_CASES.md
Raw: suite-results.json, traces/data_engine.db, traces/images/<hash>.jpg
Bản công khai: docs/build-evidence/artemis-summary.json (session IDs/image hashes).

11. AI review và hồ sơ nộp

Vòng review gốc của PR#1 trên commit749183d có10 findings thuộc6 nhóm; nhóm kiểm chứng rồi ghi quyết định chấp nhận/điều chỉnh/bác bỏ. Sáu commit sửa gốc có trace trong docs/code-review.md. Backend mới bổ sung queue thông báo theo UID/event và regression, bảo vệ owner và session khi async request đến trễ.

Finding	Quyết định / lý do	Commit
CR01 / CR05	Sửa ở service Analytics; lỗi telemetry không báo sai kết quả lưu.	59363a2
CR03	Xóa UserID Crashlytics khi logout, tránh trộn người dùng.	be41a2c
CR04	initialMessage lỗi được ghi non-fatal, không tăng crash sai.	953e9a5
CR07 / CR08	Token JSONnull và thiếuclaims bị401; test trên code cũ tìm đúng lỗi.	0873691
CR09	Bác bỏ giảm lần đọc quyền: cần phản ánh thay đổi trong Settings.	Có lý do
CR10	Dùng chung articleById để tránh hai bản logic khác nhau.	5095940

Tái kiểm tra source

flutter pub get; flutter analyze; flutter test --coverage
server: npm ci; npm run lint; npm run typecheck; npm test; npm run build
admin: npm ci; npm run lint; npm run typecheck; npm test; npm run test:e2e; npm run build
Chạy integration_test trên Android thật với API_BASE_URL của staging.

Nộp repository GitHub, báo cáoPDF12 trang này, slidePDF15 trang và video5–10 phút do nhóm quay trên máy thật. Video nên đi theo F01→F02→F03, Admin gửi push và mở đúng màn, nút crash→mở lại→Admin làm mới. Nhóm cần giải thích từng token, chữ ký media, outbox/revision và RemoteConfig defaults/cache.

GitHub repository · Web Admin · PR review gốc

Tài liệu kỹ thuật đi kèm: SYSTEM_ARCHITECTURE, API_DOCUMENTATION/OpenAPI, AUTH_AND_SECURITY, FILE_UPLOAD_FLOW, OFFLINE_SYNC, FCM_SETUP, CRASHLYTICS_INTEGRATION, DEPLOYMENT_GUIDE, TEST_RESULTS và DEVICE_ACCEPTANCE. Nguồn chấm: PRM393_Lab3_Preparation_Guide_v5_ToiUu.pdf,25trang; yêu cầu triển khai: Backendtast.docx.